The Hash Slinging Slashers

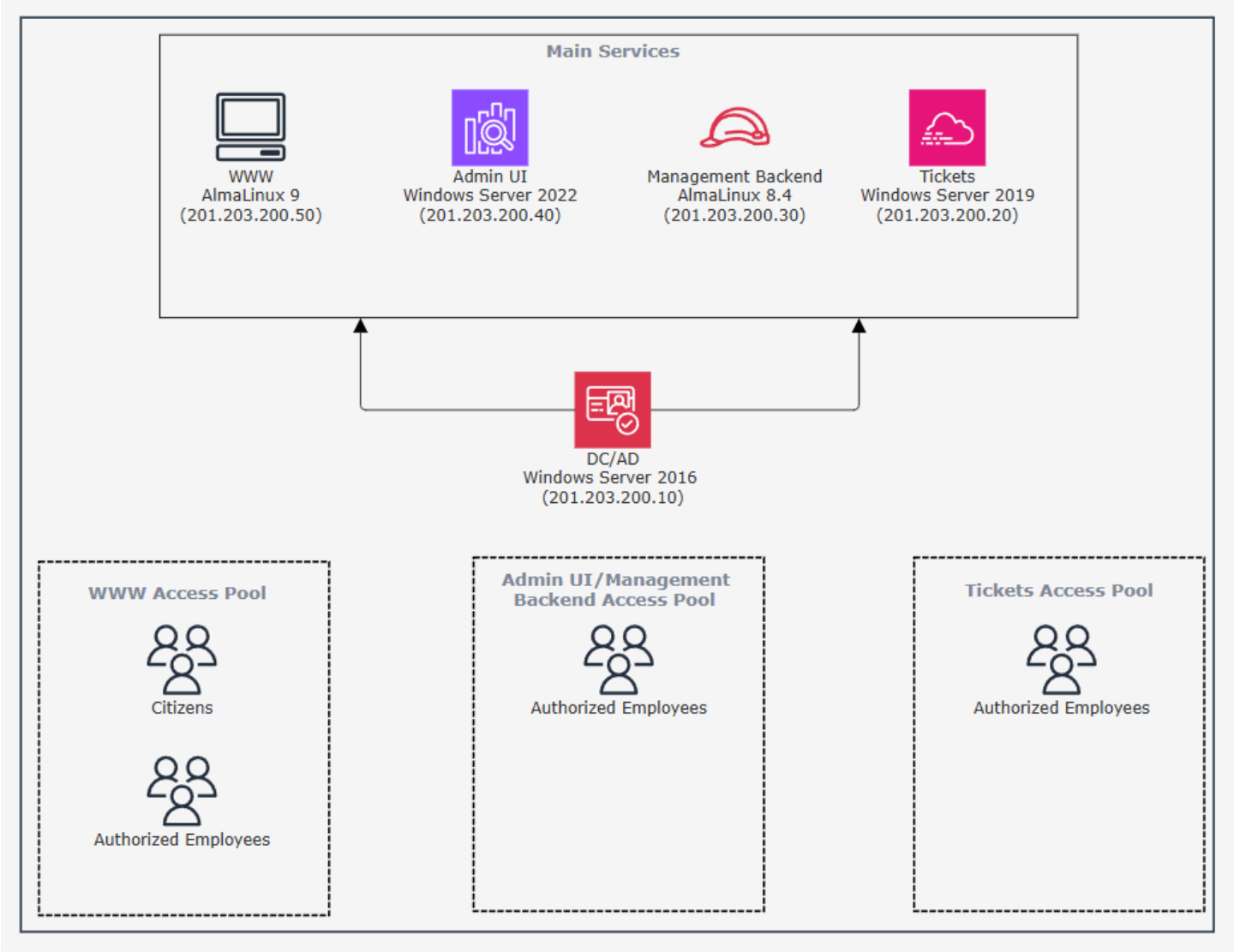
White Team Documentation

Prepared for ISU International CDC

Created by Team 3 - The Hash Slinging Slashers

Internal Network Architecture 3
Domain Controller - Detailed Server Architecture 5
Website - Detailed Server Architecture 7
Admin UI - Detailed Server Architecture 9
Management Backend - Detailed Server Architecture 11
Tickets - Detailed Server Architecture 13

Internal Network Architecture



This diagram presents a high-level view of the organization's core service infrastructure and the corresponding access control model based on role-based segmentation.

Core Components:

- Main Services
  - WWW (201.203.200.50): Public-facing web application accessed by both citizens and employees.
  - Admin UI (201.203.200.40): Internal administrative interface and system configuration and oversight.
  - Management Backend (201.203.200.30): Central backend services used for internal operations.
  - Tickets (201.203.200.20): Ticketing platform for the organization's travel system.
  - DC/AD (201.203.200.10): Domain Controller/Active Directory for centralized authentication and authorization.

Access Control Pools:

- WWW Access Pool
  - Includes both Citizens and Authorized Employees.
  - Grants access to the public-facing web service.
- Admin UI / Management Backend Access Pool
  - Restricted to Authorized Employees.
  - Grants access to internal administrative and backend services.
- Tickets Access Pool
  - Restricted to Authorized Employees.
  - Grants controlled access to the ticketing system.

Security Implications:

- All service access is governed via the Active Directory (DC/AD) at 201.203.200.10, enforcing centralized authentication.
- The design enforces least privilege principles, ensuring that users only have access to services based on their role and functional requirements.

Domain Controller - Detailed Server Architecture

System and Purpose:

- Acts as the Primary Domain Controller (PDC) for the CDCT Internal Network
- Provides:
  - Kerberos Authentication
  - LDAP/LDAPS Directory Services
  - DNS Integration
  - Group Policy Management
  - Time Synchronization (NTP) for Domain Members

Security Hardening Overview:

- Authentication Stack
  - Enforces NTLMv2 only with all LM and NTLMv1 traffic denied.
  - NTLM disabled entirely for incoming and outgoing traffic across all interfaces.
  - Minimum 128-bit encryption enforced for session security.
  - PKU2U authentication disabled to prevent peer-to-peer auth hijacking.
  - Audit policy enabled for all NTLM attempts.

- SMB Hardening:
  - SMB signing is enforced at both client and server level, preventing MiTM tampering.
  - Unencrypted passwords to third-party SMB servers are blocked.
  - Disables null sessions and anonymous access to SMB, Named Pipes, and SIDs.

- LDAP Security:
  - Machine account password changes are refused to mitigate relay and credential attacks.
  - MachineAccountQuota for normal domain users is default 0.

- User Accounts & Access Controls:
  - Guest account disabled.
  - Blank passwords blocked for local accounts.
  - UAC fully enforced for both built-in and privileged accounts.

- Login Message & User Awareness:
  - Interactive logon banner informs users of internal network policy and monitoring.

- Additional Security Controls:
  - Prevents workstation shutdown without logging in.
  - No password storage for network authentication.

Open Ports:

Port	Protocol	Service Name	Purpose/Notes
53	TCP	DNS	Domain Name System
88	TCP	Kerberos-sec	Kerberos Authentication Service
135	TCP	MS RPC	Endpoint mapper for RPC communications
389	TCP	LDAP	Directory queries
445	TCP	SMB	Used for SMB shares, GPO distribution
464	TCP	kpasswd	Kerberos password change service
593	TCP	ncacn_http	RPC over HTTP
636	TCP	LDAPS	Secure LDAP
3268	TCP	LDAP GC	Global Catalog
3269	TCP	LDAPS GC	Secure Global Catalog
3389	TCP	RDP	Remote Desktop Protocol
9389	TCP	mc-nmf	.NET Message Framing
49666-52939	TCP	Dynamic RPC	DCOM/RPC Communications

Website - Detailed Server Architecture

System and Purpose:

- Acts as the Primary landing page for end users, ticket purchases, and tracking of services.
- Provides:
  - Purchasing of tickets
  - Transit Machine dashboard
  - Seamless integration with Active Directory
  - Stored user data and login forms
  - Active registration of new users

Security Hardening Overview:

- Authentication Stack
  - BLANK

- SMB Hardening:
  - SMB signing is enforced at both client and server level, preventing MiTM tampering.
  - Unencrypted passwords to third-party SMB servers are blocked.
  - Disables null sessions and anonymous access to SMB, Named Pipes, and SIDs.

- SSH Security:
  - Only IT Administrators and Domain Administrators can SSH into this machine.
  - Disabled ROOT Login to this device.
  - Disabled Empty Passwords for all user
  - Enabled PAM
  - Turned off Permit Tunnel
  - Client Alive Interval set to 300 and Client Alive Max to 1
  - Login Grace Time is set to 30 seconds & Strict Mode is Enabled
  - Max SSH Attempts is set to 3
  - Max Concurrent Sessions is set to 4
  - Verbose Logging is enabled
  - X11 forwarding is disabled

- User Accounts & Access Controls:
  - BLANK
  - BLANK
  - BLANK

- Additional Security Controls:
  - Port 1337 is suspected to be a backdoor/listener. We have purposefully left this port active, but filtered it, so that we can log attempts to reach it/investigate further.

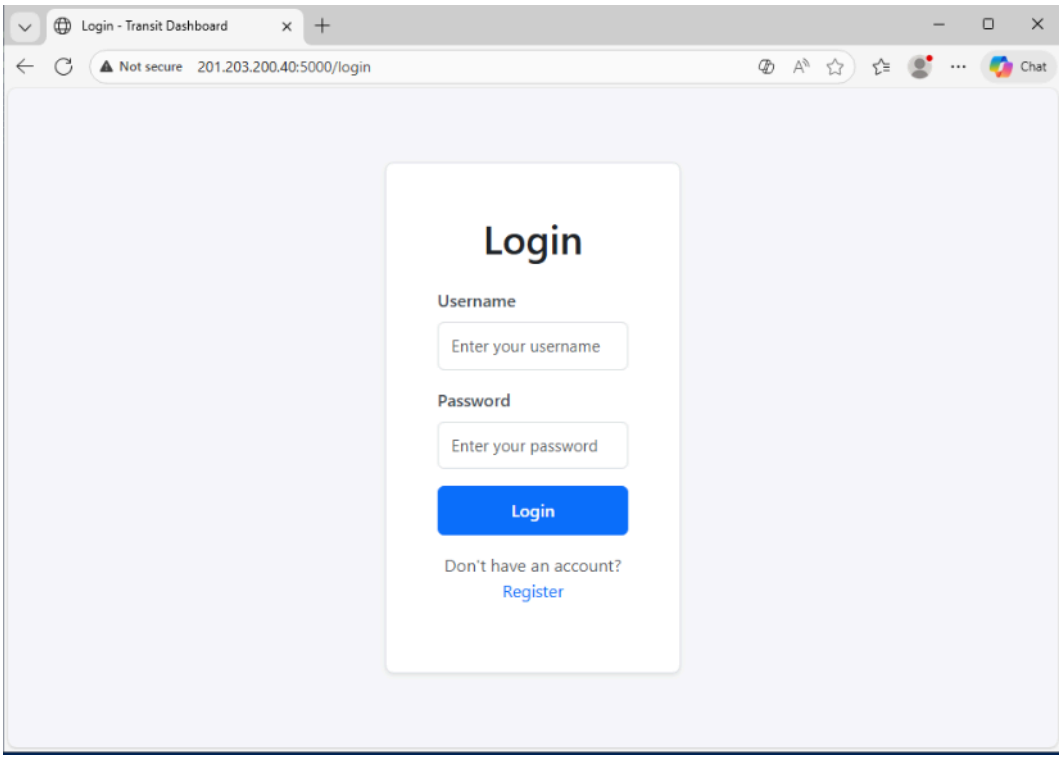
Open Ports:

Port	Protocol	Service Name	Purpose/Notes
22	TCP	DNS	Administrative SSH access on the device.
80	TCP	http	Used for website hosting.
1337	TCP	waste	Filtered with a firewall, suspected backdoor, left here to monitor attempts/distract attackers.
5000	TCP	http	The website is hosted on port 5000.

Admin UI - Detailed Server Architecture

System and Purpose:

- Acts as the Administrative interface for IT Administrators to RDP into and access the Transit Machine Dashboard.
- Provides:
  - Authentication via backend '/auth/*' endpoints.
  - Account management and password change features.
  - Dashboard with vehicle tracking visualization.
  - Fleet management with bus/train filtering



Security Hardening Overview:

- Authentication Stack
  - Removed the suspicious user account 'scrat'
  - Removed the suspicious user account 'nsa'
  - Removed the user account 'cdc'
  - Removed 'guest' from the Administrators group
  - Removed 'guest' from the Remote Desktop group

- Additional Security Controls:
  - Port 1337 is suspected to be a backdoor/listener. We have purposefully left this port active, but filtered it, so that we can log attempts to reach it/investigate further.

Open Ports:

Port	Protocol	Service Name	Purpose/Notes
135	TCP	MS RPC	Endpoint mapper for RPC communications
445	TCP	SMB	Used for SMB shares, GPO distribution
3389	TCP	RDP	Remote Desktop Protocol
5000	TCP	UPnP	Universal Plug and Play
49664-49687	TCP	Dynamic RPC	DCOM/RPC Communications

Management Backend - Detailed Server Architecture

System and Purpose:

- Acts as the backend for the Website, Tickets Machine, and Administrative UI.
- Provides:
  - Authentication via backend '/auth/*' endpoints.
  - Account management and password change features.
  - Dashboard with vehicle tracking visualization.
  - Fleet management with bus/train filtering.

Security Hardening Overview:

- Authentication Stack
  - Adjusted backend authentication pieces to ensure proper LDAP login management.
  - Configuration files adjusted to better suit business needs and security protocols.
  - Adjusted Vehicle Routes to ensure proper communication of accurate data.

- SSH Security
  - Only IT Administrators and Domain Administrators can SSH into this machine.
  - Disabled ROOT Login to this device.
  - Disabled Empty Passwords for all user
  - Enabled PAM
  - Turned off Permit Tunnel
  - Client Alive Interval set to 300 and Client Alive Max to 1
  - Login Grace Time is set to 30 seconds & Strict Mode is Enabled
  - Max SSH Attempts is set to 3
  - Max Concurrent Sessions is set to 4
  - Verbose Logging is enabled
  - X11 forwarding is disabled

- Additional Security Controls:
  - Service Hardening
    - Identified unnecessary RPCBind (port 111) exposure during external enumeration.
    - Verified no dependent services (NFS, mountd, lockd) were running.
    - Stopped rpcbind service to eliminate active process.
    - Disabled rpcbind service to prevent startup at boot.
    - Stopped rpcbind.socket to prevent systemd socket activation.
    - Disabled rpcbind.socket to prevent automatic service triggering.
    - Masked rpcbind service and socket to prevent future unintended reactivation.
    - Validated closure of TCP/UDP port 111 via ss and external scanning.

Open Ports:

Port	Protocol	Service Name	Purpose/Notes
22	TCP	OpenSSH	Allows secure shell login to the device.
3306	TCP	MySQL	Database for the Backend/Website.
5000	TCP	HTTP	Web port over HTTP.

Tickets - Detailed Server Architecture

System and Purpose:

- Acts as the ticket management portal for the Website.
- Provides:
  - Tickets to the website.
  - Holds the master certificate that is used to sign all other certificates.

Security Hardening Overview:

- Authentication Stack
  - Adjusted backend authentication pieces to ensure proper LDAP login management.
  - Configuration files adjusted to better suit business needs and security protocols.
  - Adjusted Vehicle Routes to ensure proper communication of accurate data.

- SSH Security
  - Only IT Administrators and Domain Administrators can SSH into this machine.
  - Disabled ROOT Login to this device.
  - Disabled Empty Passwords for all user
  - Enabled PAM
  - Turned off Permit Tunnel
  - Client Alive Interval set to 300 and Client Alive Max to 1
  - Login Grace Time is set to 30 seconds & Strict Mode is Enabled
  - Max SSH Attempts is set to 3
  - Max Concurrent Sessions is set to 4
  - Verbose Logging is enabled
  - X11 forwarding is disabled

Open Ports:

Port	Protocol	Service Name	Purpose/Notes
22	TCP	OpenSSH	Allows secure shell login to the device.
3306	TCP	MySQL	Database for the Backend/Website.
5000	TCP	HTTP	Web port over HTTP.